

1. บทนำ

1.1 ภาพรวมของระบบ (System Overview)

PaiNamNae เป็นระบบสำหรับจองการเดินทางระหว่างผู้โดยสาร (Passenger) และผู้ขับขี่ (Driver) โดยผู้โดยสารสามารถทำการจองการเดินทางผ่านระบบ และเมื่อการเดินทางเสร็จสิ้น ผู้ใช้สามารถดำเนินการต่าง ๆ ภายในระบบ เช่น การจัดการบัญชีผู้ใช้ (User Account) และการยืนยันตัวตนเพื่อเข้าถึงบริการต่าง ๆ ระบบมีส่วนของ **Authentication API** ที่ทำหน้าที่ในการจัดการบัญชีผู้ใช้และความปลอดภัยของรหัสผ่าน เช่น การสร้างบัญชีผู้ใช้ (Create User), การเข้าสู่ระบบ (Login), การตรวจสอบความถูกต้องของรหัสผ่าน (Password Validation) และการเปลี่ยนรหัสผ่าน (Change Password)

เพื่อเพิ่มความปลอดภัยของระบบ รหัสผ่านของผู้ใช้จะต้องเป็นไปตาม **NCSC Password Policy** ซึ่งกำหนดเงื่อนไขต่าง ๆ เช่น

- รหัสผ่านต้องมีความยาวอย่างน้อย 8 ตัวอักษร
- รหัสผ่านต้องประกอบด้วยอย่างน้อย 3 คำ
- รหัสผ่านต้องไม่เป็นคำที่พบบ่อย (Common Password)
- รหัสผ่านต้องไม่อยู่ในรายการต้องห้าม (Blacklist)
- รหัสผ่านต้องไม่ประกอบด้วยข้อมูลของผู้ใช้ เช่น username หรือ email

นอกจากนี้ระบบยังมีมาตรการด้านความปลอดภัยเพิ่มเติม เช่น

- การล็อกบัญชีเมื่อเข้าสู่ระบบผิดหลายครั้ง
- การบังคับให้เปลี่ยนรหัสผ่านเมื่อรหัสผ่านหมดอายุ

1.2 วัตถุประสงค์ในการทดสอบ (Purpose of Test)

เพื่อทดสอบการทำงานของ **Authentication และ Password API** ว่าสามารถทำงานได้ถูกต้องตามข้อกำหนดของระบบ โดยมีวัตถุประสงค์ดังนี้

- ตรวจสอบว่าสามารถสร้างบัญชีผู้ใช้ใหม่ได้สำเร็จ
- ตรวจสอบว่าสามารถเข้าสู่ระบบ (Authentication) ได้เมื่อใช้ข้อมูลที่ต้องการ
- ตรวจสอบว่าระบบสามารถบังคับใช้ **Password Policy** ตามมาตรฐาน **NCSC** ได้อย่างถูกต้อง
- ตรวจสอบว่าระบบสามารถป้องกันการใช้รหัสผ่านที่ไม่ปลอดภัย เช่น common password หรือ blacklist password
- ตรวจสอบว่าระบบสามารถป้องกันการใช้รหัสผ่านเดิมซ้ำได้

- ตรวจสอบว่าระบบสามารถล็อกบัญชีเมื่อเข้าสู่ระบบผิดหลายครั้ง
- ตรวจสอบว่าระบบตอบสนองต่อคำขอภายในเวลาที่กำหนด

การทดสอบนี้ใช้วิธีการทดสอบแบบอัตโนมัติ (Automated Testing) เพื่อจำลองการใช้งานของผู้ใช้ผ่าน API

2. วิธีการทดสอบและกระบวนการทดสอบ (Test Methodology and Test Process)

ผู้ทดสอบดำเนินการทดสอบในระดับ **User Acceptance Test (UAT)** โดยใช้เครื่องมือ **Robot Framework** ร่วมกับ **RequestsLibrary** เพื่อส่ง HTTP Request ไปยัง REST API ของระบบโดยตรง ซึ่งเป็นการทดสอบในลักษณะ **Black-box Testing** โดยผู้ทดสอบจะตรวจสอบเฉพาะผลลัพธ์ของระบบโดยไม่พิจารณาโครงสร้างภายในของโปรแกรม

การทดสอบแบ่งออกเป็น 3 ประเภท ได้แก่

1. **Functional Testing** ทดสอบการทำงานหลักของระบบ เช่น การสร้างบัญชีผู้ใช้ การเข้าสู่ระบบ และการเปลี่ยนรหัสผ่าน
2. **Validation Testing** ทดสอบการตรวจสอบความถูกต้องของข้อมูล เช่น การตรวจสอบเงื่อนไขของรหัสผ่านตามนโยบายความปลอดภัย
3. **Performance Testing** ทดสอบความเร็วในการตอบสนองของ API และความเสถียรของระบบเมื่อมีการเรียกใช้งานหลายครั้งต่อเนื่อง

กระบวนการดำเนินการทดสอบมีขั้นตอนดังนี้

1. สร้าง Session เพื่อเชื่อมต่อกับ Backend Server
2. ทำการ Login เพื่อรับ **Authentication Token**
3. ส่งคำขอ (POST / PUT) ไปยัง API ที่เกี่ยวข้องกับการจัดการรหัสผ่าน
4. ตรวจสอบ **HTTP Status Code** และผลลัพธ์ที่ตอบกลับจากระบบ
5. บันทึกผลการทดสอบและสรุปรายงานผล

3. สภาพแวดล้อมในการทดสอบ (Testing Environment)

3.1 ฮาร์ดแวร์ (Hardware)

Processor 12th Gen Intel(R) Core(TM) i5-12500H (2.50 GHz)

Installed RAM 16.0 GB (15.7 GB usable)

System type 64-bit operating system, x64-based processor

3.2 ซอฟต์แวร์ (Software)

Operating System: Windows 10

Backend Server: Node.js

Database: PostgreSQL

Testing Tool: Robot Framework 7.4.1 (Python 3.12.1 on win32)

robotframework-seleniumlibrary : 6.8.0

Web Browser: Microsoft Edge

Visual Code Studio

3.3 ผู้ทดสอบ (Human)

ชื่อ นายเจษฎา กองศักดิ์ รหัสนักศึกษา 663380248-7 section

Test Scenario ID:	API-PasswordAPI-001	Project ID:	PaiNamNae		
Test Scenario Name:	Password API – Functional Testing	Tested by:	Chetsada Kongsak		
UAT Name:	Password_API_Functional_Test	Version:	V1.0		
Date of Test:	17/03/2569				
Pre-requisite:	ระบบ API ทำงานปกติ Admin account สามารถ login ได้ มี endpoint สำหรับ create user				
Description:	ทดสอบการทำงานหลักของ Password API เช่น การสร้าง account, การ login, การเปลี่ยนรหัสผ่าน, การตรวจสอบ policy ของ password				
No.	Test Case and Steps	Expected Result	Actual Result	Test Result (Pass/Fail)	Remark
1	POST /api/users (Create new account)	201			
2	POST /api/auth/validate-password (password < 8)	400			
3	POST /api/auth/validate-password (password มี username/email)	400			
4	POST /api/auth/validate-password (password < 3 words)	400			

5	POST /api/auth/validate-password (common password)	400			
6	POST /api/auth/validate-password (blacklist password)	400			
7	POST /api/auth/login (valid password)	200			
8	PUT /api/auth/change-password (valid change)	200			
9	PUT /api/auth/change-password (reuse old password)	400			

Test Scenario ID:	API-PasswordAPI-002	Project ID:	PaiNamNae		
Test Scenario Name:	Password API – Security & Business Rules	Tested by:	Chetsada Kongsak		
UAT Name:	Password_API_Security_Test	Version:	V1.0		
Date of Test:	17/03/2569				
Pre-requisite:	User account ถูกสร้างเรียบร้อยแล้ว				
Description:	ทดสอบ security rule ของระบบ เช่น Account lock, Password expiration				
No.	Test Case and Steps	Expected Result	Actual Result	Test Result (Pass/Fail)	Remark
1	POST /api/auth/login (wrong password 3 times)	403			
2	POST /api/auth/login (after password expired)	200 + requirePasswordChange=true			

Test Scenario ID:	API-PasswordAPI-003	Project ID:	PaiNamNae		
Test Scenario Name:	Password API – Performance Testing	Tested by:	Chetsada Kongsak		
UAT Name:	Password_API_Performance_Test	Version:	V1.0		
Date of Test:	17/03/2569				
Pre-requisite:	Database พร้อมใช้งาน, Server ทำงานปกติ				
Description:	ทดสอบความเร็วในการตอบสนองของ API และความเสถียรของระบบเมื่อเรียกใช้งานหลายครั้งต่อเนื่อง				
No.	Test Case and Steps	Expected Result	Actual Result	Test Result (Pass/Fail)	Remark
1	POST /api/auth/login (ตรวจสอบ response time)	< 5 วินาที			
2	Sequential login 5 times	ไม่เกิด error			

รายงานสรุปผลการทดสอบ (Test Summary Report)

Scenario ID	Scenario Name	Test Case#	Pass	Fail	No run	Block	Remark	Defect ID
API-PasswordAPI-001	Password Functional Test	9						
API-PasswordAPI-002	Password Security Test	2						
API-PasswordAPI-003	Password Performance Test	2						
รวม		13						